

AN TOÀN THÔNG TIN (INSE330380)

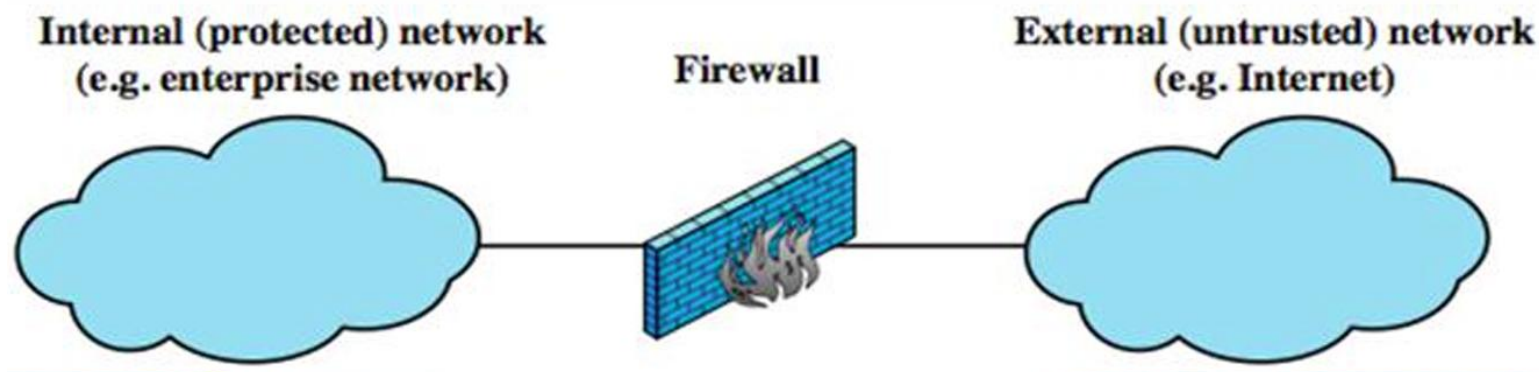
CHƯƠNG VI FIIREWALL VÀ IDS/IPS

Ths. ĐỖ MINH HẬU

- ☐ Giới thiệu bài học
- ☐ Firewall: khái niệm, nguyên tắc hoạt động, các dạng firewall
- ☐ IDS/IPS: khái niệm, nguyên tắc hoạt động, các kỹ thuật IDS
- ☐ Tóm tắt
- ☐ Quizze

- ❑ Hiện nay, nhiều tổ chức công ty đã có nhiều giải pháp đối phó với nguy cơ và tấn công trên mạng, một trong các giải pháp được sử dụng phổ biến và hiệu quả đó là Firewall, IDS/ IPS.
- ❑ Firewall giám sát và kiểm soát lưu lượng mạng đến và đi dựa trên các quy tắc bảo mật được xác định trước cho nên các lưu lượng mạng nguy hiểm chứa đựng mối đe dọa và tấn công sẽ bị chặn lại trước khi đi vào mạng nội bộ bên trong.
- ❑ IDS/IPS có thể phát hiện (IDS) được các tấn công và có thể chặn (IPS)

- ❑ Tường lửa (Firewall) là hệ thống bảo mật mạng kiểm soát lưu lượng vào/ra và cho phép/chặn dựa trên chính sách (rules).
- ❑ Firewall thường đặt ở biên mạng giữa mạng nội bộ và mạng không tin cậy (Internet) (và cũng có thể đặt giữa các vùng mạng như LAN–DMZ, user–server).
- ❑ Tiền thân của firewall là lọc gói & ACL trên router (packet filtering).



- ☐ Appliance (thiết bị chuyên dụng): Fortinet FortiGate, Palo Alto, Cisco, Check Point...
- ☐ Software (cài trên OS): Linux nftables/iptables, Windows Defender Firewall...
- ☐ Virtual (VM/ảo hoá): Palo Alto VM-Series, FortiGate-VM...
- ☐ Cloud-managed / FWaaS: AWS Network Firewall, Azure Firewall, cloud NGFW...

Firewall – Khả năng và giới hạn

☐ Khả năng:

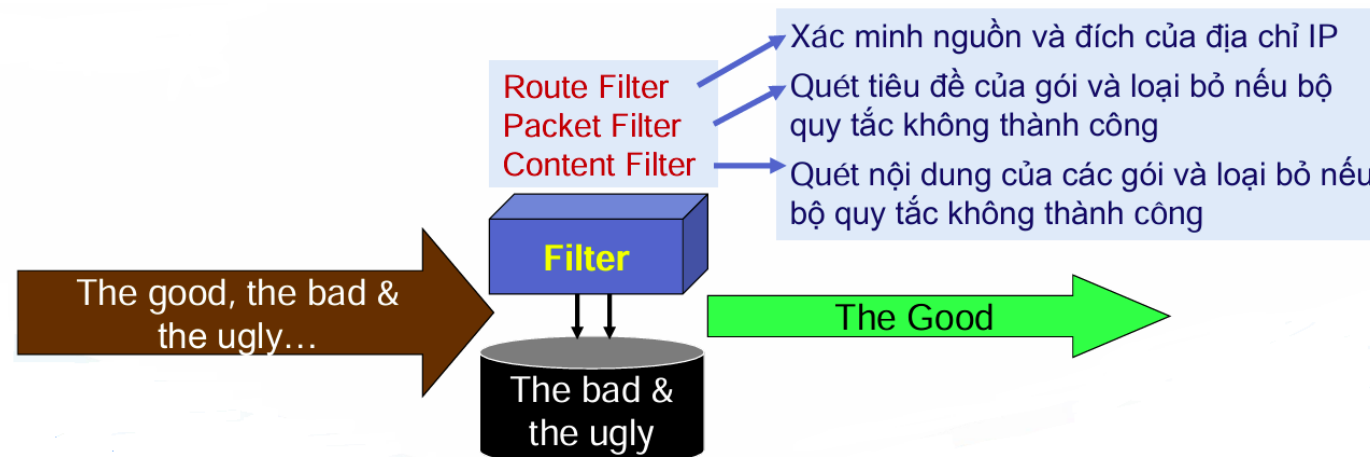
- Điểm kiểm soát tập trung (check point): cho phép/chặn lưu lượng theo chính sách (policy/rules), giảm bề mặt tấn công.
- Phân tách vùng mạng (segmentation): LAN–DMZ–Internet, user–server, chi nhánh–trụ sở.
- Ghi log & giám sát: cung cấp dữ liệu cho cảnh báo/SIEM/điều tra sự cố.
- Tích hợp dịch vụ mạng (tùy loại firewall/NGFW): NAT, IPsec VPN, QoS, kiểm soát ứng dụng, đôi khi IDS/IPS.

Firewall – Khả năng và giới hạn

❑ Hạn chế:

- Không chặn được tấn công không đi qua firewall (bypass).
- Không thay thế bảo mật ứng dụng/endpoint: malware, lỗ hổng ứng dụng, cấu hình yếu vẫn có thể bị khai thác.
- Mã hóa (TLS/HTTPS) hạn chế khả năng kiểm tra nội dung nếu không triển khai SSL inspection.

- ❑ Chính sách kiểu allowlist (default deny): chỉ cho phép lưu lượng được phép rõ ràng theo rule.
- ❑ Chính sách kiểu blocklist (default allow): cho phép mặc định, chỉ chặn những mẫu/điều kiện bị cấm.
- ❑ Firewall quyết định dựa trên: IP/port/protocol, trạng thái phiên (stateful), và có thể ứng dụng/nội dung (L7) nếu là NGFW/Proxy (đặc biệt khi có TLS thì cần SSL inspection).
- ❑ Sơ đồ hoạt động



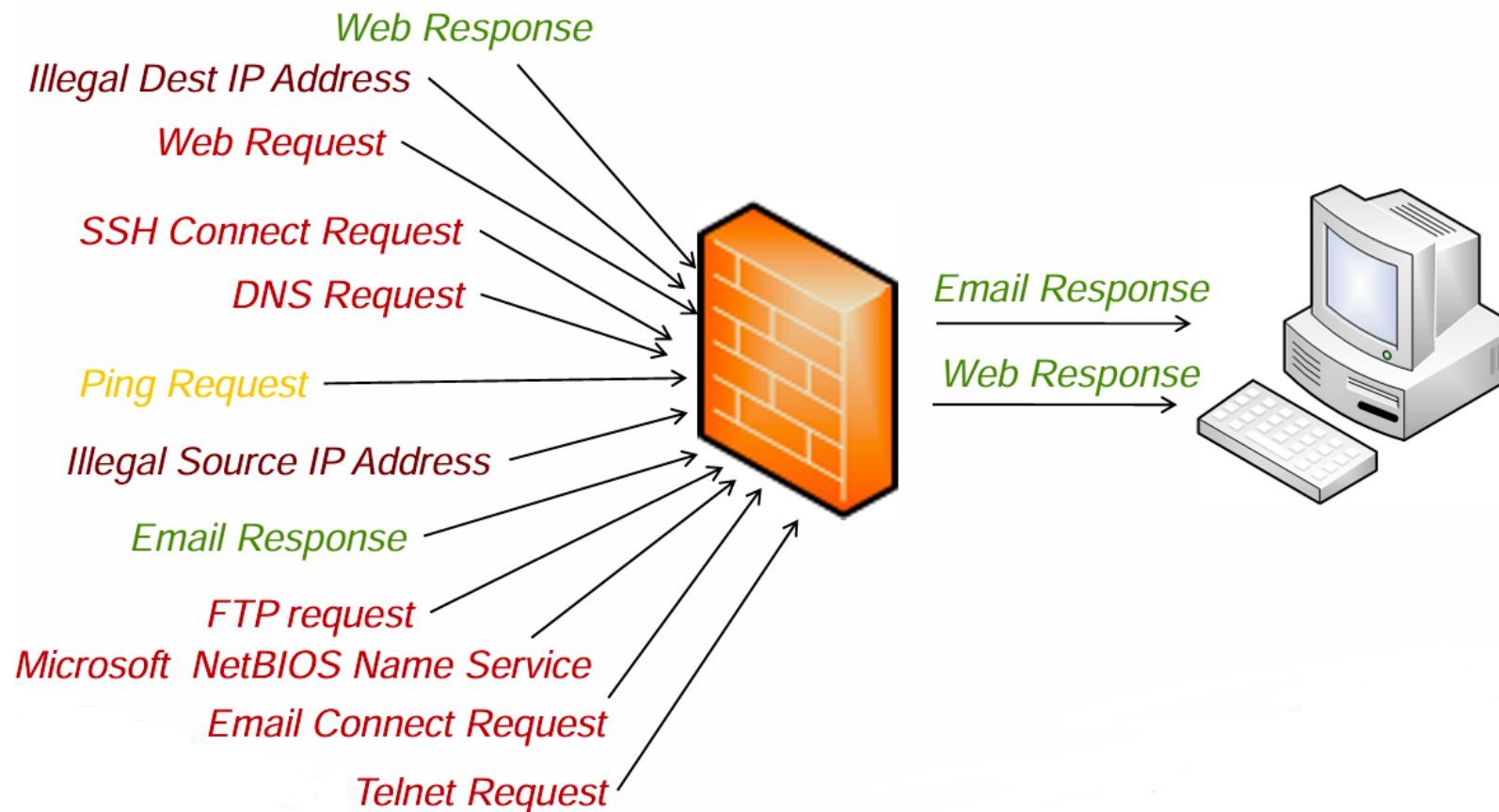
❑ Tùy thuộc vào loại tường lửa, nó có thể kiểm tra:

- Header của gói tin (IP/port/protocol, flags...)
- Trạng thái phiên (state) từ chuỗi gói (session table)
- Nội dung/ứng dụng (L7) (phụ thuộc loại firewall và mã hóa TLS)

❑ Các kiểu Firewall:

- Packet Filtering Firewall (L3/L4, stateless)
- Stateful Inspection Firewall (theo trạng thái kết nối)
- Circuit-Level Gateway (kiểm soát phiên/handshake, ví dụ SOCKS)
- Application-Level Gateway (Proxy Firewall) (L7, hiểu giao thức ứng dụng)

Bộ lọc sẽ xem xét các gói đến, gồm Request và Response.



- ❑ Kiểm tra tiêu đề gói (header), không đọc nội dung ứng dụng
 - IP nguồn/đích, protocol (TCP/UDP/ICMP)
 - Port nguồn/đích, TCP flags (SYN/ACK), interface/zone
- ❑ Cách ra quyết định: so khớp gói tin với rule → allow / deny / log
- ❑ Bắt tốt (ở mức mạng):
 - Chặn theo IP/port/protocol (ví dụ Telnet/NetBIOS)
 - Anti-spoofing (chặn IP nguồn “không hợp lệ”)
 - Chặn lưu lượng “không đúng hướng” (inbound/outbound policy)
- ❑ Ưu điểm: rất nhanh, ít tốn tài nguyên, phù hợp lưu lượng lớn
- ❑ Hạn chế: thường stateless, không hiểu ứng dụng (HTTP/HTTPS), khó chặn tấn công L7

1. IP Spoofing (giả mạo IP nguồn)

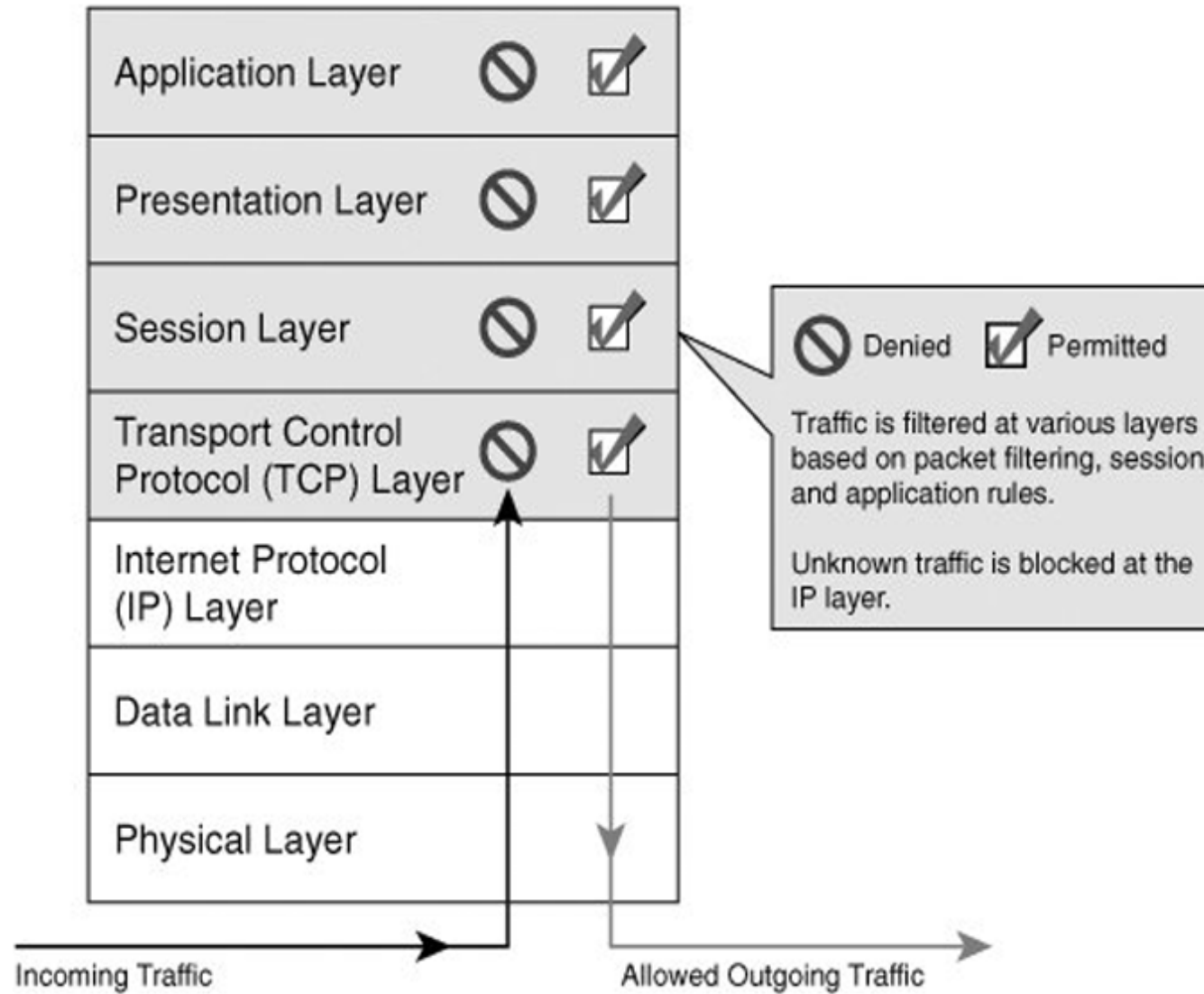
- ☐ Mục tiêu: giả IP nội bộ để vượt rule tin cậy
- ☐ Đối phó: Anti-spoofing
- ☐ Chặn gói từ ngoài vào mà có source IP thuộc mạng nội bộ/private
- ☐ Áp dụng ingress/egress filtering tại biên (edge)

2. Source Routing (định tuyến nguồn – IP Options LSRR/SSRR)

- ☐ Mục tiêu: ép đường đi của gói tin để né kiểm soát
- ☐ Đối phó: Drop tất cả packet có IP Source Route / IP Options (không cho dùng tùy chọn này)

3. Tiny Fragments / Fragmentation Evasion (phân mảnh nhỏ để né lọc port)

- ❑ Mục tiêu: làm TCP/UDP header không nằm trong fragment đầu → firewall không đọc được port/flags để lọc
- ❑ Đối phó:
 - Chặn/giới hạn fragment bất thường (tiny fragments)
 - Yêu cầu fragment đầu phải chứa đủ header L4 (hoặc reassemble trước khi lọc)



- ❑ Có “trí nhớ” về kết nối (state table): lưu thông tin phiên như 5-tuple (src IP, dst IP, src port, dst port, protocol) và trạng thái TCP
- ❑ Chỉ cho phép gói “hợp lệ theo trạng thái”
 - Ví dụ: gói inbound thuộc kết nối đã được tạo từ bên trong → được phép (return traffic)
 - Gói “lạ” không khớp state → chặn
- ❑ Bắt tốt hơn packet filtering (stateless) đối với:
 - Scan/giả mạo theo phiên, gói TCP không đúng cờ (flags), lưu lượng “out-of-state”
 - Nhiều tấn công nhiều gói cần ngưỡng cảnh kết nối
- ❑ Chi phí/hiệu năng: an toàn hơn stateless nhưng tốn CPU/RAM hơn do phải lưu và tra state (thường vẫn đủ nhanh cho đa số mạng doanh nghiệp)

❑ Kết hợp 2 việc:

- Lọc theo header (IP/port/protocol/TCP flags)
- Lưu trạng thái kết nối vào state table (flow/phiên đang hoạt động)

❑ Chỉ cho phép gói “đúng trạng thái”

- Gói inbound chỉ được phép nếu thuộc một kết nối đã được thiết lập hợp lệ
- Gói không khớp state (out-of-state) → drop / log

❑ Hiểu TCP handshake & kết thúc kết nối

- Tạo state khi thấy SYN (bắt đầu)
- Cập nhật khi SYN/ACK, ACK (đã thiết lập)
- Xóa state khi FIN/RST hoặc timeout

❑ Chống né lọc tốt hơn stateless

- Chặn nhiều gói “bất thường”: ACK không có phiên, SYN không hợp lệ, TCP flags lạ, flow sai chiều
- (tùy thiết bị) có thể kiểm tra thêm sequence/ack hợp lệ trong một cửa sổ để giảm giả mạo gói

1. Connection / Circuit-level Gateway

- Xác thực user trước, sau đó cho phép thiết lập phiên/kết nối (TCP circuit)
- Kiểm soát tốt theo ai được kết nối với ai, nhưng không soi sâu nội dung L7

2. Cut-through Proxy (Authenticated session + L3/L4 enforcement)

- Xác thực user trước, sau đó lưu lượng được cho đi nhanh và áp rule chủ yếu theo L3/L4 (IP/port/protocol, có thể kèm state)
- Nhanh hơn proxy L7 đầy đủ, nhưng kiểm soát nội dung ứng dụng kém hơn

- ❑ Hoạt động ở Session layer, kiểm soát tính hợp lệ của phiên/kết nối giữa hai điểm cuối.
- ❑ Theo dõi trạng thái kết nối bằng bảng phiên/bảng trạng thái (session/state table).
- ❑ Ví dụ: giám sát yêu cầu thiết lập phiên mới; kiểm tra TCP 3-way handshake để xác minh phiên hợp lệ.
- ❑ Giới hạn: thường không kiểm tra nội dung ứng dụng (payload), nên không lọc được lệnh/URL chi tiết như firewall tầng ứng dụng.

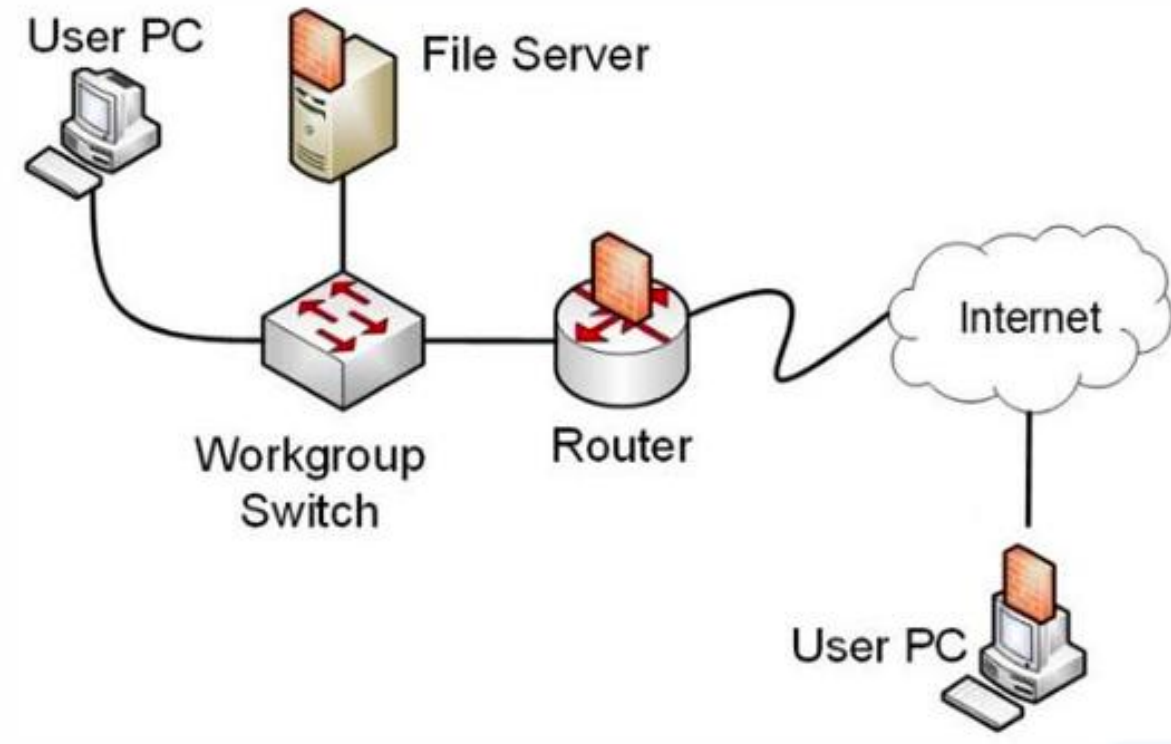
- ❑ Lọc ở lớp ứng dụng (Application Layer – L7): hiểu ngữ nghĩa giao thức như HTTP/HTTPS, FTP, SMTP, DNS...
- ❑ Cơ chế proxy (thường gặp):
 - Client kết nối tới proxy/firewall
 - Proxy mở kết nối mới tới server $\Rightarrow$ tách 2 phiên để kiểm soát chi tiết
- ❑ Có thể áp quy tắc theo nội dung ứng dụng:
 - HTTP: domain/URL path, method (GET/POST), header, file type, policy upload/download
 - FTP: chặn lệnh nguy hiểm, kiểm soát passive/active
 - SMTP: chặn loại file đính kèm, lọc nội dung theo policy

- ❑ Ưu điểm: kiểm soát chi tiết, chặn tốt nhiều tấn công/vi phạm policy ở L7
- ❑ Hạn chế: tốn CPU/RAM hơn, độ trễ cao hơn, cần cấu hình theo từng ứng dụng; với HTTPS thường cần TLS inspection mới nhìn được nội dung

- ❑ Hoạt động như proxy ở lớp ứng dụng (L7): đứng giữa client và server
- ❑ Tách kết nối thành 2 phiên riêng:
 - Client $\rightleftarrows$ Gateway (proxy)
 - Gateway $\rightleftarrows$ Server
- ❑ Gateway có thể thực hiện:
 - Xác thực người dùng/thiết bị, áp chính sách truy cập theo ứng dụng
 - Kiểm tra cú pháp/lệnh/nội dung của giao thức (HTTP/FTP/SMTP...)
 - Ghi log chi tiết theo hoạt động ứng dụng

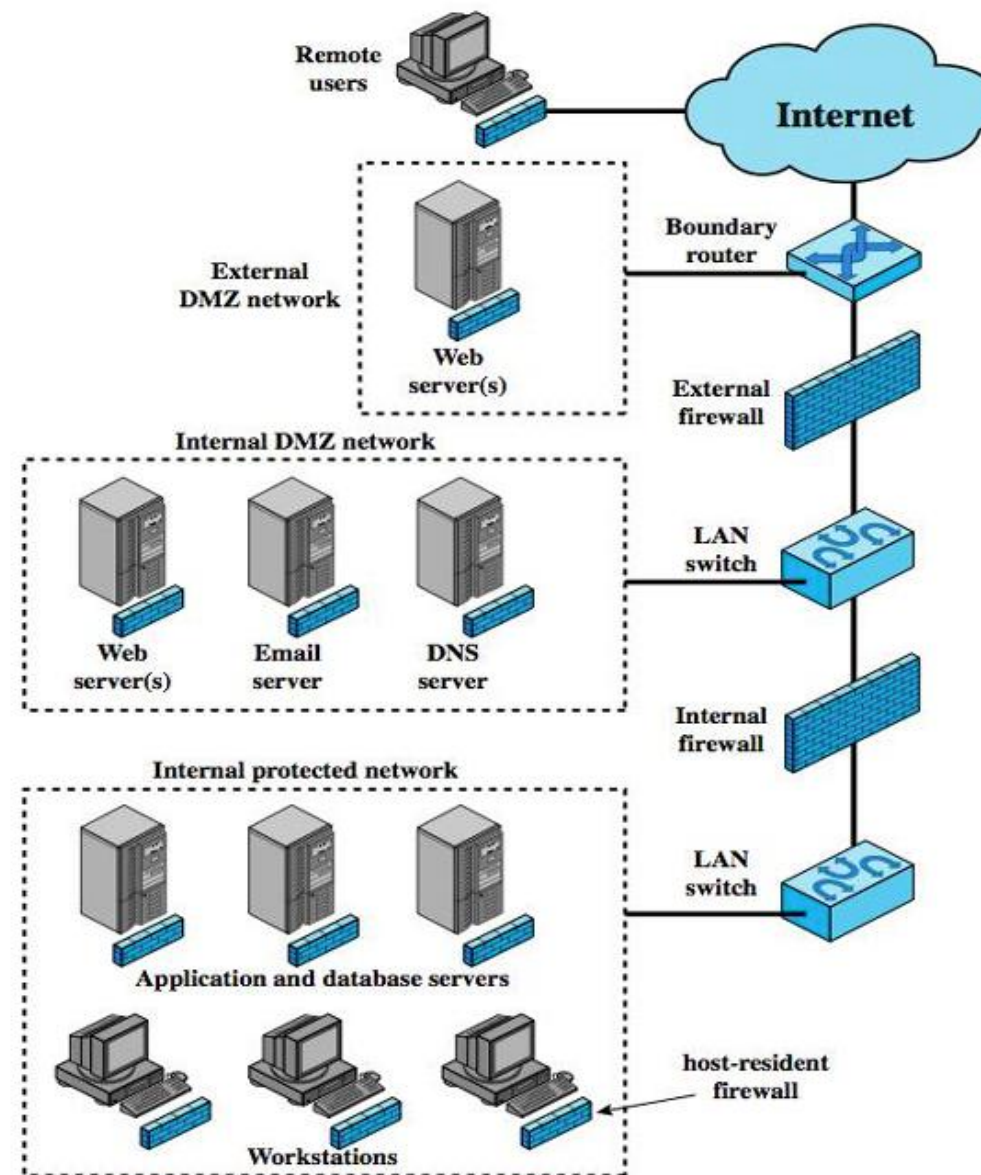
- ❑ Proxy theo từng ứng dụng: cần module hiểu giao thức $\Rightarrow$ có thể không hỗ trợ đủ mọi tính năng/ứng dụng lạ.
- ❑ Ưu/nhược:
 - An toàn & kiểm soát chi tiết hơn packet filtering/stateful
 - Chi phí cao hơn (tài nguyên, độ trễ, vận hành/cấu hình)

- ❑ Là phần mềm Firewall chạy trên PC/ Server.
- ❑ Firewall trên PC cá nhân thì được gọi Firewall cá nhân. Điều này thường được sử dụng để nâng cao giải pháp bảo mật hoặc để cung cấp khả năng bảo vệ bổ sung cho máy tính cá nhân.
- ❑ Firewall trên Server thường lọc gói đơn giản để lọc trên giao thức IP, TCP hoặc UDP, được xây dựng để cung cấp một giải pháp thay thế chi phí thấp

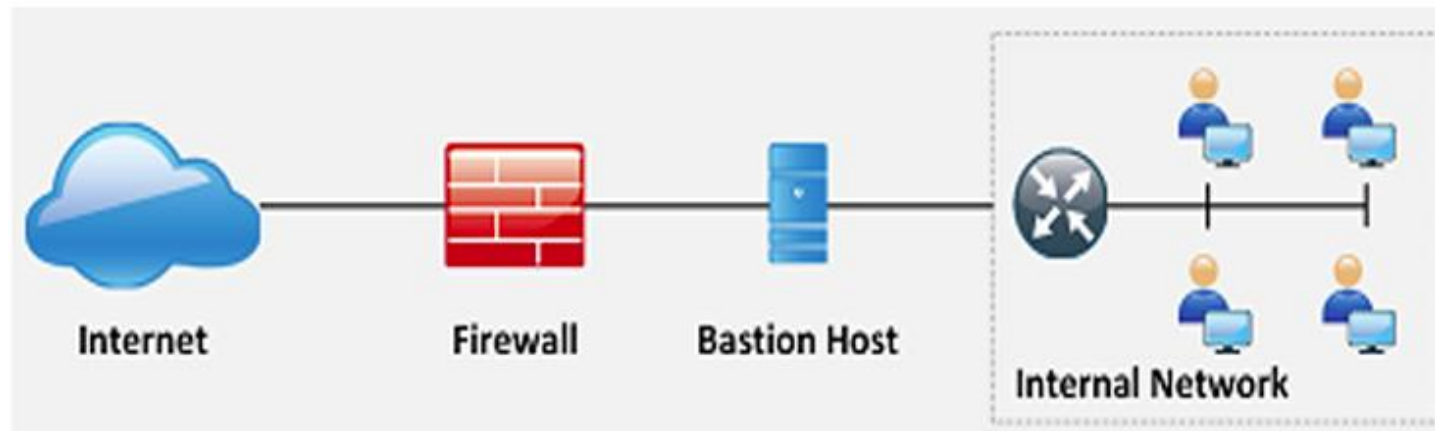


Vị trí Firewalls

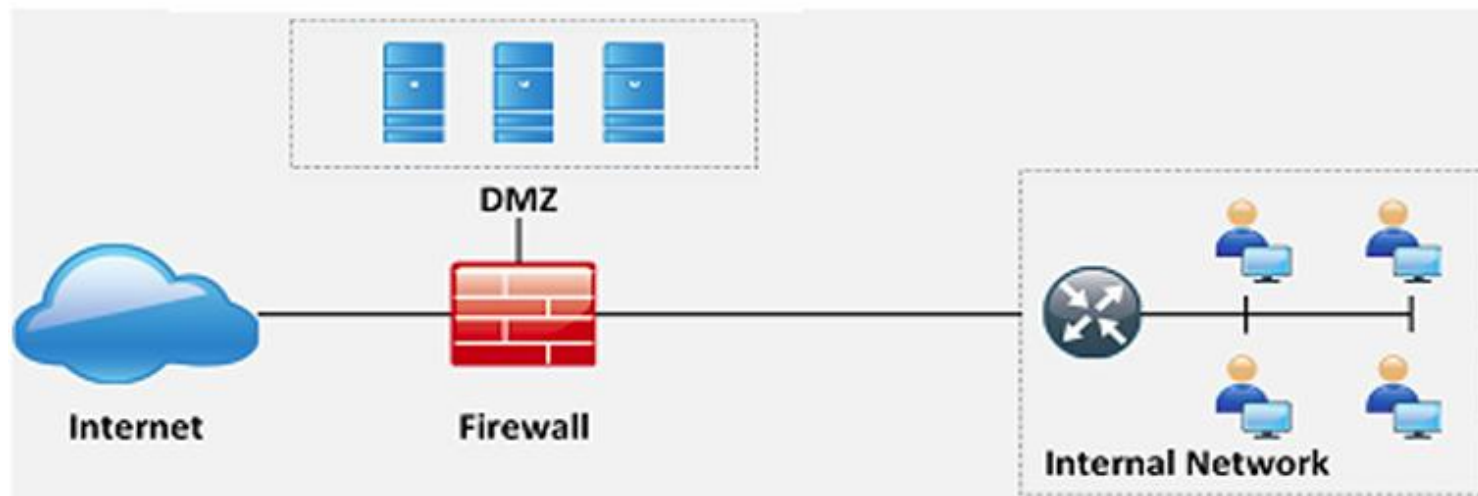
- ☐ External Firewall: Bảo vệ vùng biên
- ☐ Internal Firewall: Bảo vệ mạng cục bộ
- ☐ Host-based Firewall: Bảo vệ các Server



Bastion Host: điểm
giao cắt nơi mọi lưu
lượng mạng đều đi
qua

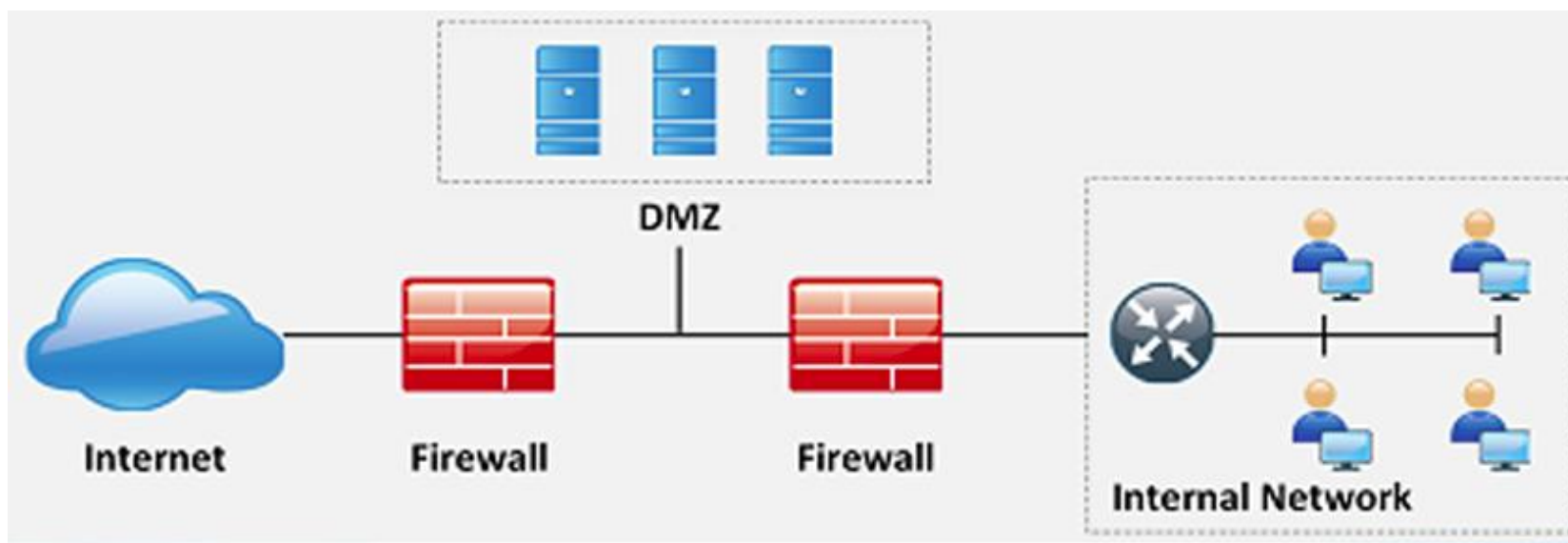


Screened Subnet:
các zone được phân
chia không làm ảnh
hưởng nhau

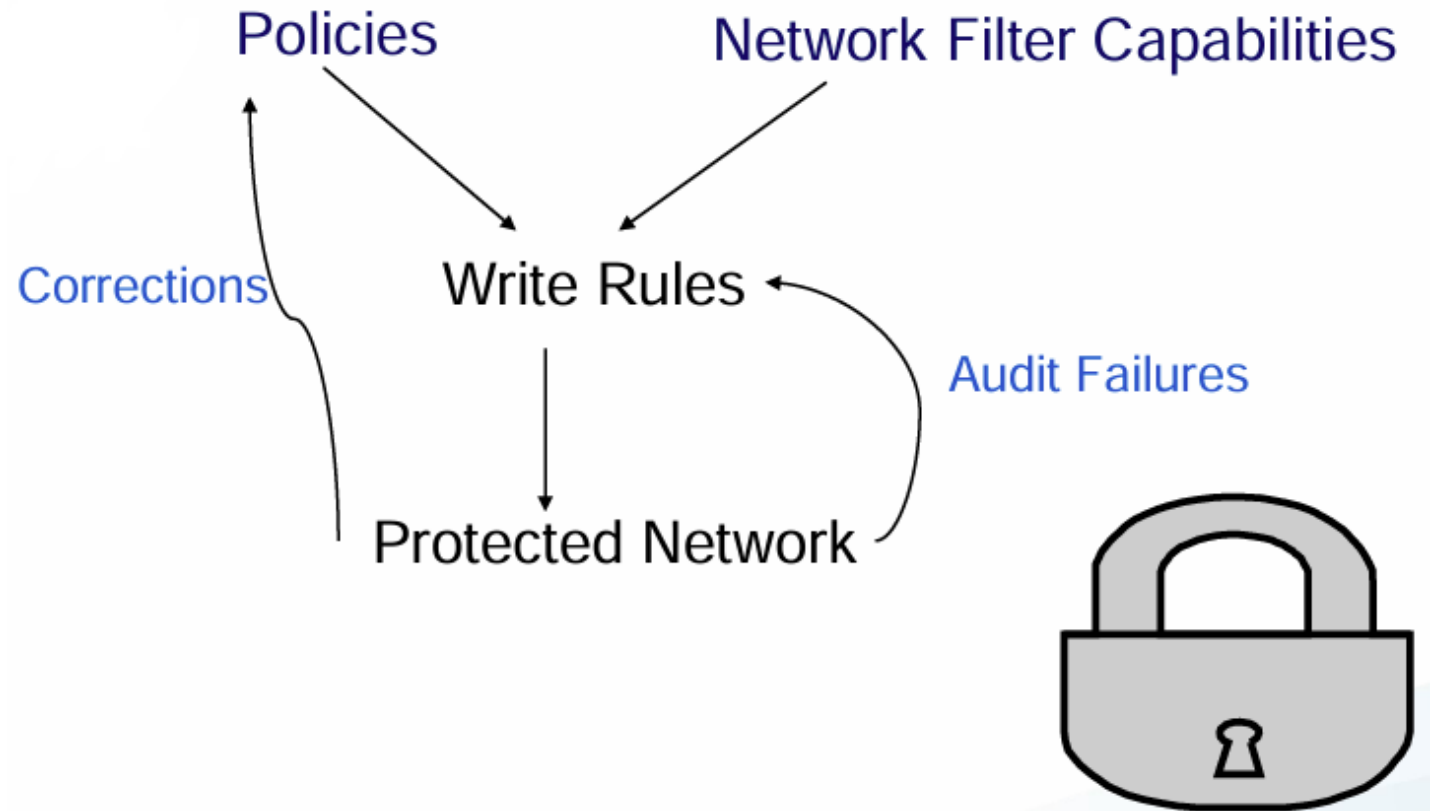


Multi-homed: Nó làm tăng hiệu quả và độ tin cậy của mạng.

DMZ hoặc khu phi quân sự (mạng ngoại vi hoặc mạng con được sàng lọc) là một mạng con vật lý hoặc logic có chứa và hiển thị các dịch vụ của một tổ chức hướng ra bên ngoài cho một tổ chức khác không đáng tin cậy (Internet).



Chính sách của Firewall được thực hiện thông qua các rule được định nghĩa bởi người quản trị



Rule Set A

action	ourhost	port	theirhost	port	comment
block	*	*	SPIGOT	*	we don't trust these people
allow	OUR-GW	25	*	*	connection to our SMTP port

Rule Set C

action	ourhost	port	theirhost	port	comment
allow	*	*	*	25	connection to their SMTP port

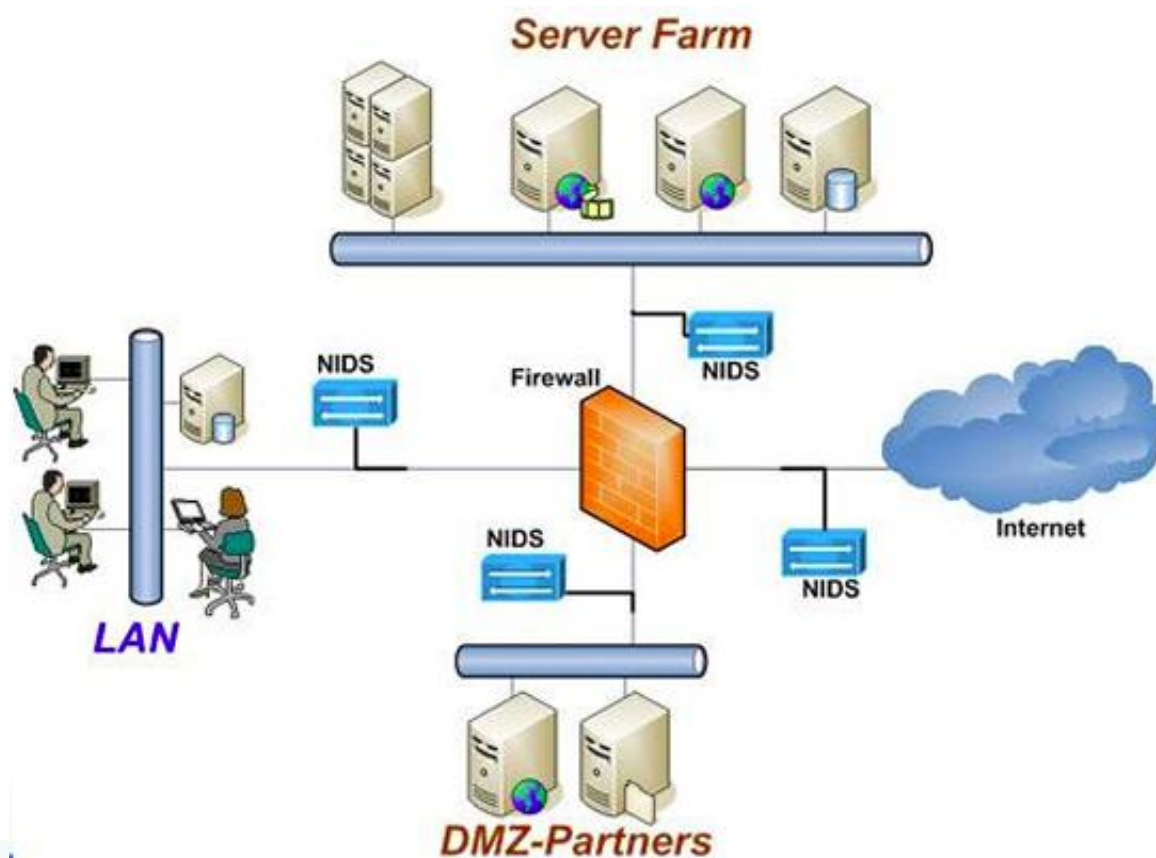
Rule Set D

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	25		our packets to their SMTP port
allow	*	25	*	*	ACK	their replies

Rule Set E

action	src	port	dest	port	flags	comment
allow	{our hosts}	*	*	*		our outgoing calls
allow	*	*	*	*	ACK	replies to our calls
allow	*	*	*	>1024		traffic to nonservers

Hệ thống phát hiện xâm nhập IDS là một thiết bị hoặc ứng dụng phần mềm giám sát lưu lượng mạng nhằm phát hiện những bất thường, các hoạt động trái phép xâm nhập vào hệ thống, đồng thời cảnh báo cho quản trị hệ thống để có phản ứng kịp thời.

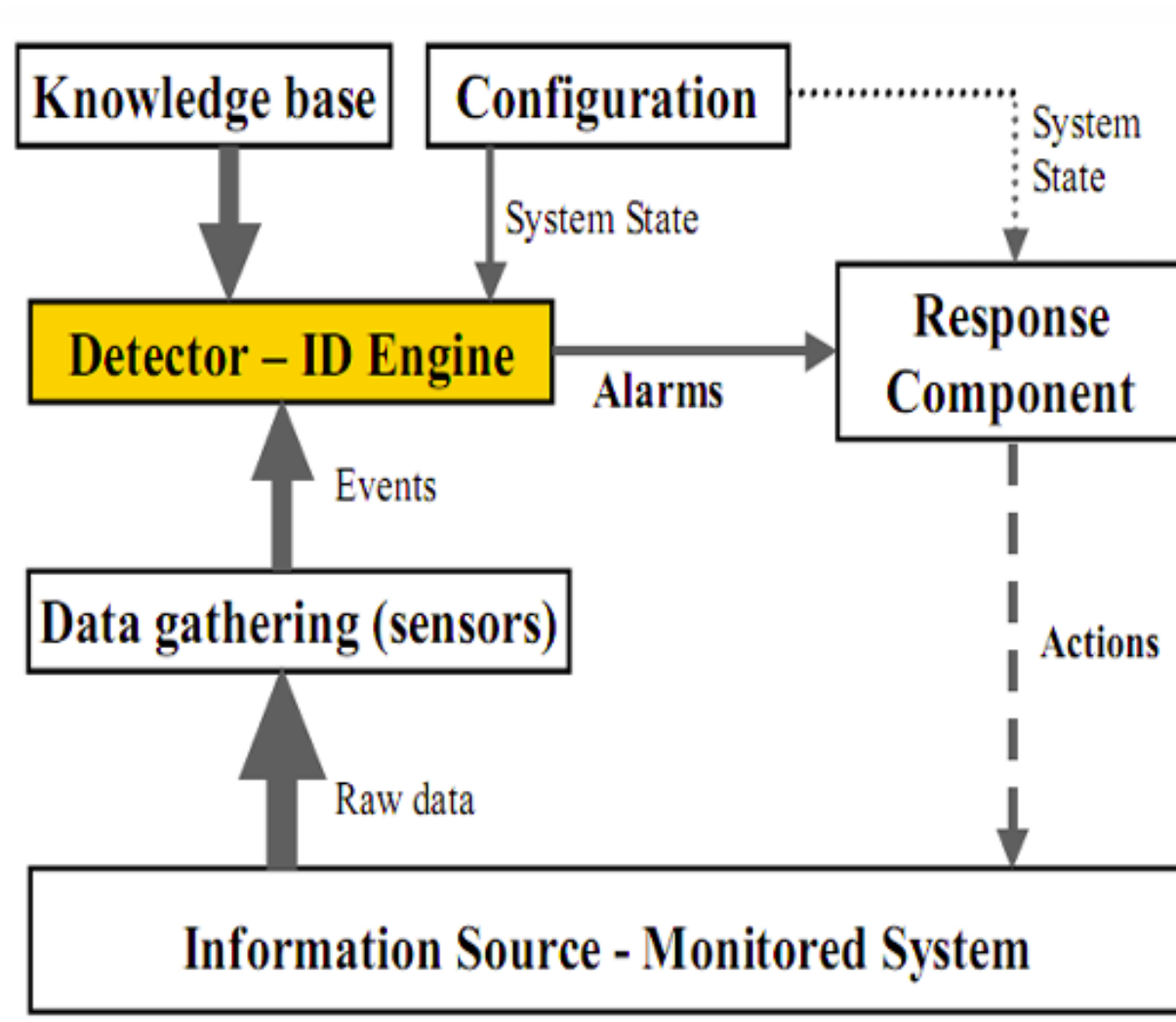


Một IDS bao gồm ba thành phần logic:

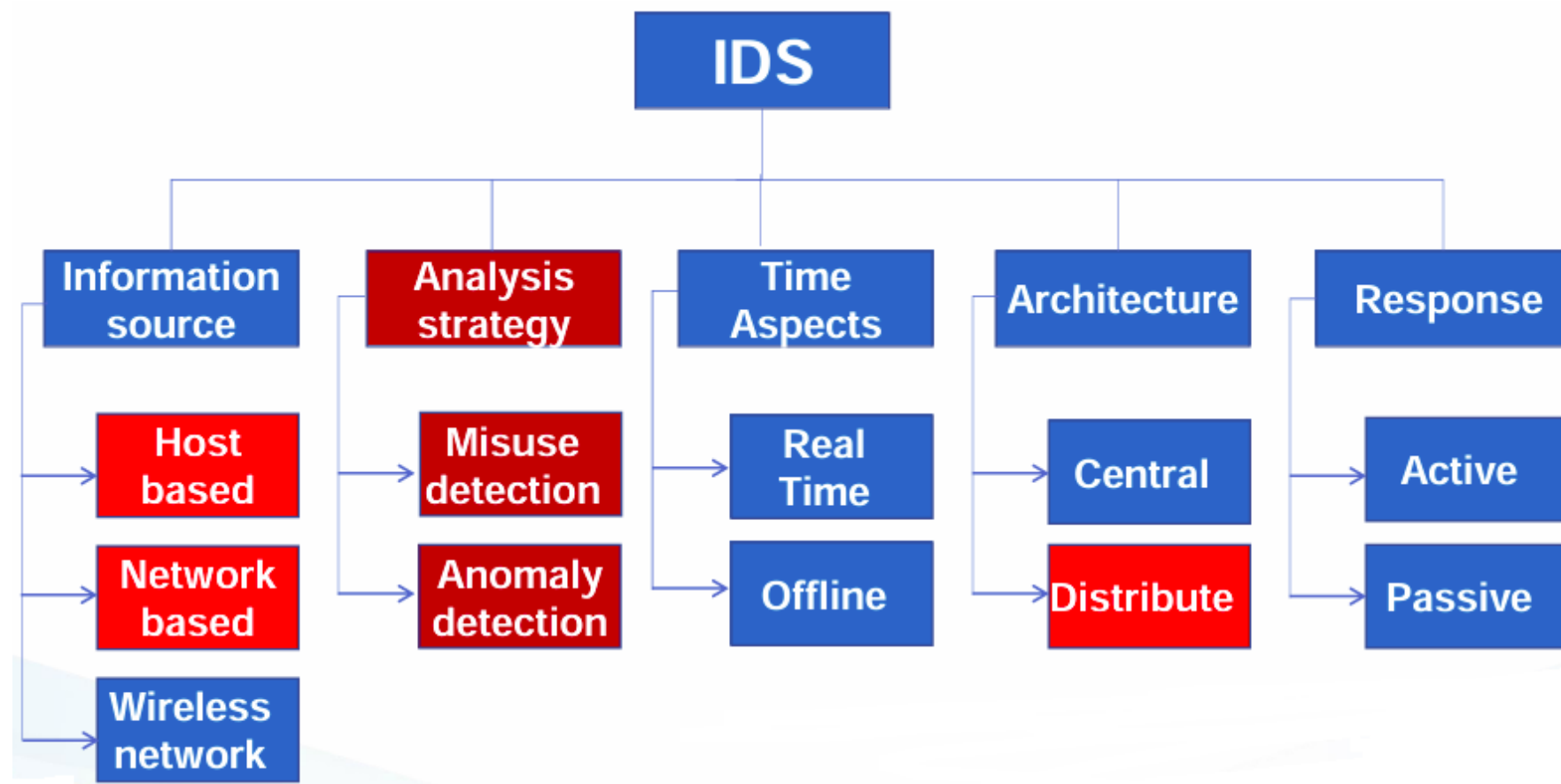
- ☐ Cảm biến (Sensor): có nhiệm vụ thu thập dữ liệu.
- ☐ Máy phân tích (Analyzers): dựa vào các kỹ thuật khác nhau để xác định xem có sự xâm nhập đã xảy ra hay không
- ☐ Giao diện người dùng (User interface): cho phép người dùng xem đầu ra từ hệ thống hoặc kiểm soát hành vi của hệ thống

Sơ đồ hoạt động của IDS

- ❑ Data gathering device (sensor): thu thập dữ liệu
- ❑ Detector: phân tích dữ liệu để xác định các hành vi xâm nhập. Detector cần có hỗ trợ bởi hai thành phần.
 - Knowledge base (database): Cơ sở tri thức này có thể là: Các dấu hiệu tấn công đã được biết trước (signature-based), hoặc profile về các hành vi hợp pháp trong hệ thống (anomaly-based).
 - Configuration: cung cấp các thông tin về cấu hình hiện tại của IDS
- ❑ Response component: bắt đầu các hành động khi một hành vi xâm nhập được phát hiện

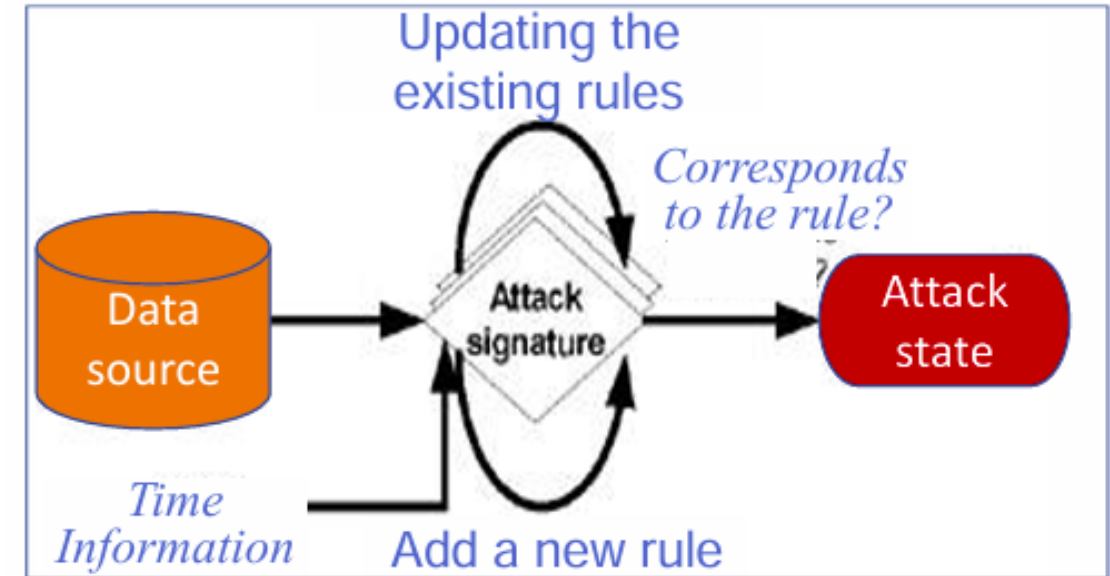


Dựa vào các yếu tố khác nhau có thể phân loại IDS thành các loại sau



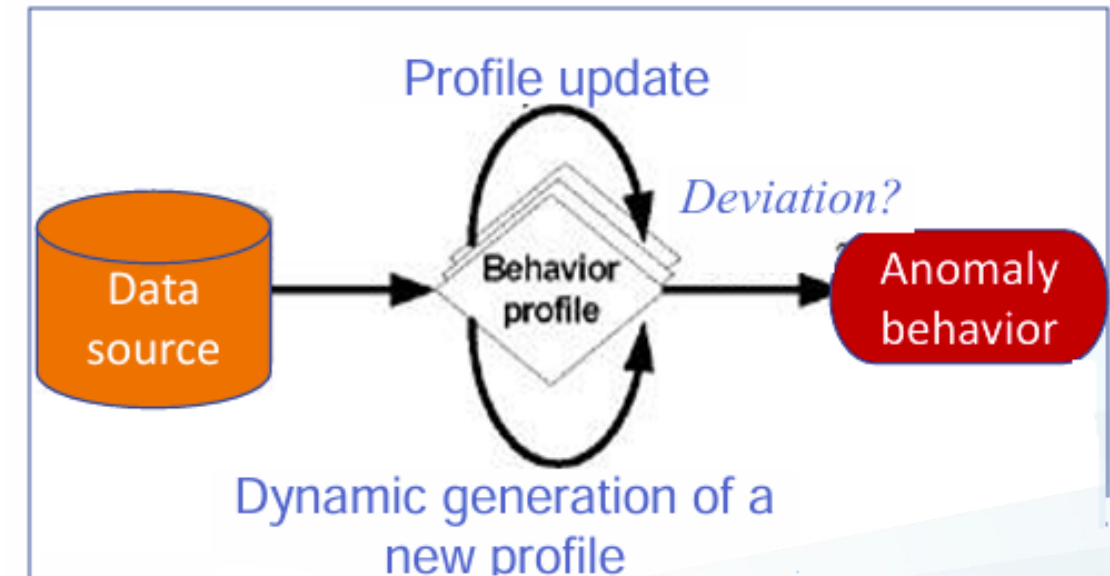
❑ Signature-based IDS

Phụ thuộc vào các mẫu phù hợp được thu thập từ các cuộc tấn công đã biết

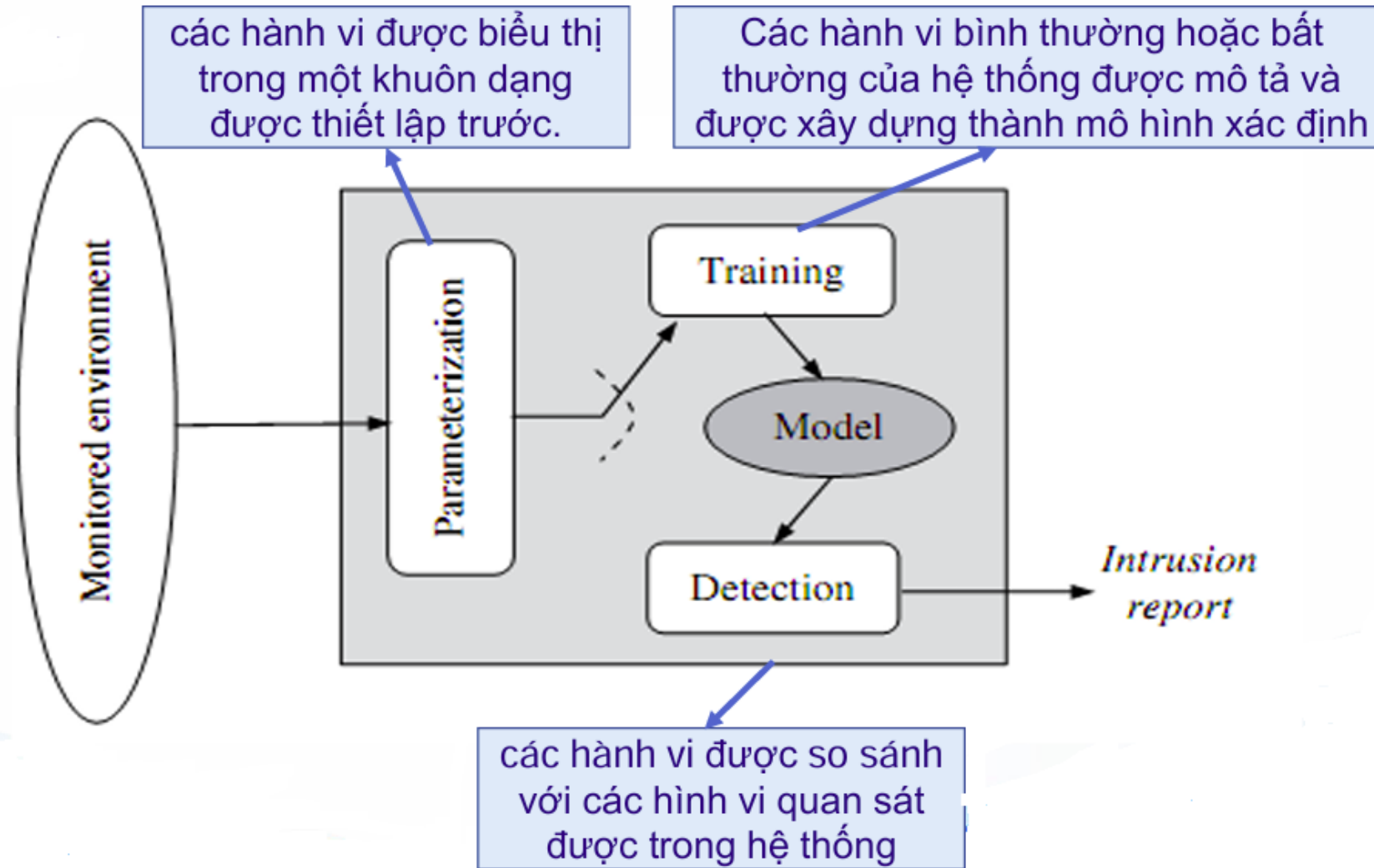


❑ Anomaly-based IDS

Thông qua việc quan sát và mô hình hóa liên tục các hành vi thông thường, hệ thống sẽ tìm thấy các mối đe dọa có thể xảy ra do sai lệch so với mô hình thông thường hoặc việc phân loại được thực hiện.



Mô hình hoạt động



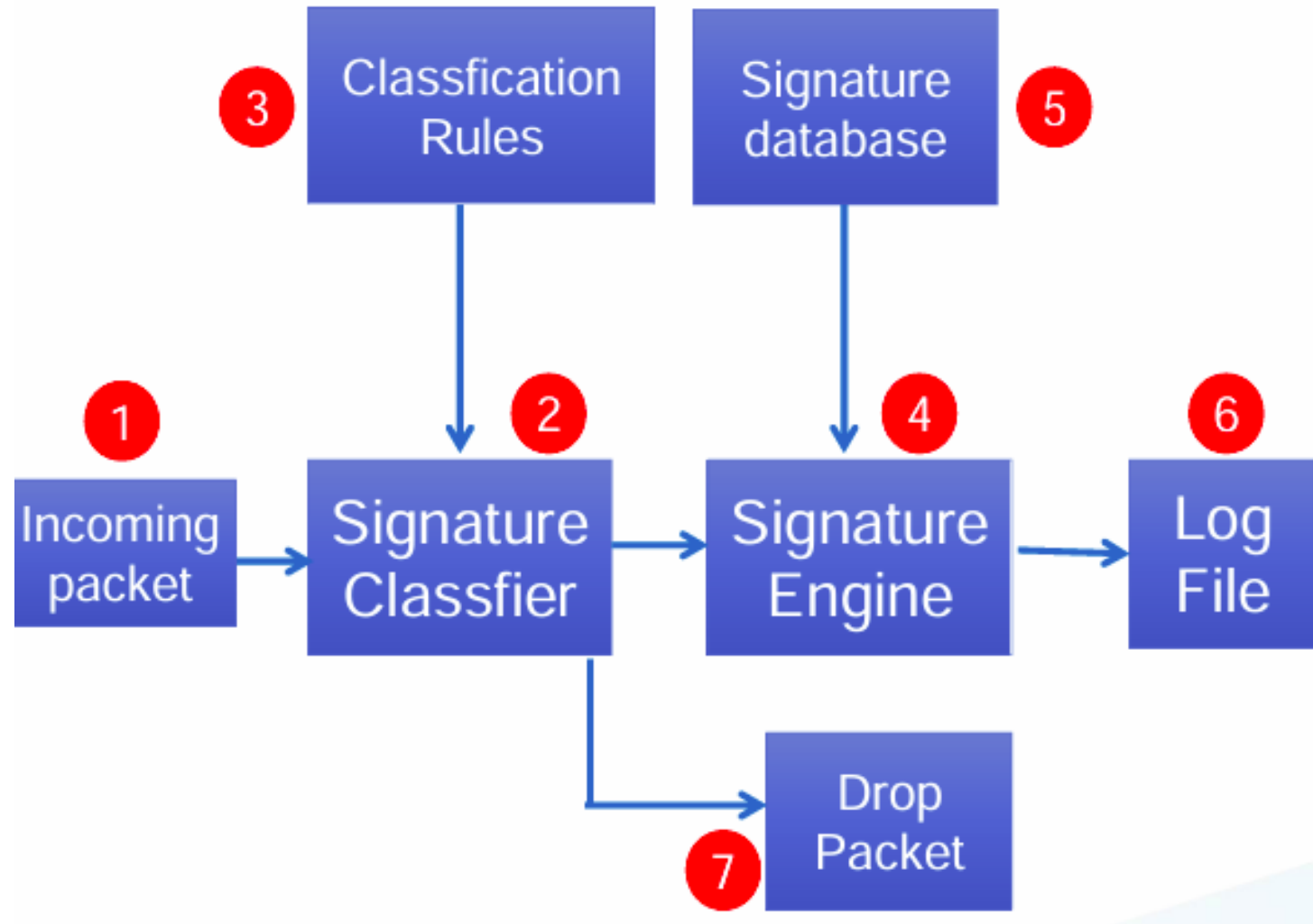
□ Ưu điểm:

- Phát hiện các cuộc tấn công nội bộ dựa trên các hoạt động thông thường được thu thập trong hệ thống;
- Khả năng phát hiện các cuộc tấn công chưa biết trước đó;
- Kẻ tấn công rất khó biết được hoạt động chắc chắn nào có thể được thực hiện mà không tạo ra cảnh báo.

❑ Hạn chế:

- Hệ thống phải trải qua giai đoạn đào tạo trong huấn luyện hành vi người dùng phù hợp bằng cách xác định hành vi lưu lượng truy cập thông thường, đây là một công việc khó khăn và tiêu tốn nhiều thời gian.
- Bởi vì nó đang tìm kiếm các sự kiện bất thường hơn là các cuộc tấn công nên chúng sẽ tạo ra các cảnh báo sai khi có hành vi bất thường nhưng không phải là một cuộc tấn công.

Sơ đồ hoạt động:



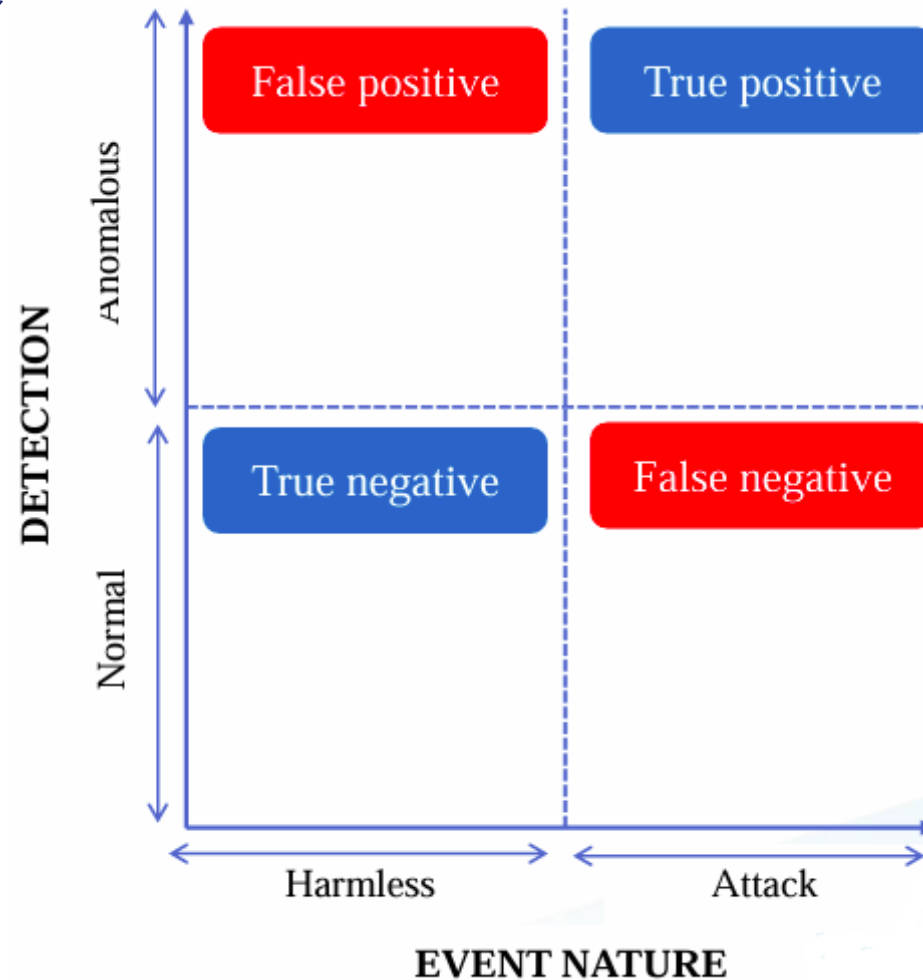
Sơ đồ hoạt động:

dòng dữ liệu (1) đi vào Bộ phận phân loại (2) sẽ được phân loại theo các luật phân loại (3) đã được qui định trước. Kết quả phân loại cũng có thể được lưu trữ lại (7). Sau đó, được chuyển tới bộ phận tìm kiếm dấu hiệu (4).

Bộ phận tìm kiếm dấu hiệu (4) sẽ thực hiện so khớp gói tin với các dấu hiệu đã định nghĩa (5) để phát hiện hành vi xâm nhập. Thông tin về các hành vi xâm nhập được phát hiện được gửi về log file (6), sau đó cảnh báo cho admin

- ❑ Hoạt động của các kỹ thuật Signature-based quan sát các sự kiện trên hệ thống và áp dụng một bộ quy tắc để quyết định đối với xâm nhập
- ❑ Các tiếp cận:
 - Phát hiện bất thường dựa trên nguyên tắc: phân tích hồ sơ kiểm toán lịch sử cho hành vi dự kiến, sau đó kết hợp với hành vi hiện tại
 - Xác định thâm nhập dựa trên nguyên tắc:
 - Quy tắc xác định đã biết thâm nhập / điểm yếu
 - Thường bằng cách phân tích các kịch bản tấn công từ Internet
 - Bổ sung quy định từ các chuyên gia bảo mật

- ❑ False alarm –cảnh báo sai: là hiện tượng hệ thống IDS phát hiện ra tấn công hoặc hành vi bình thường bị sai so với thực tế



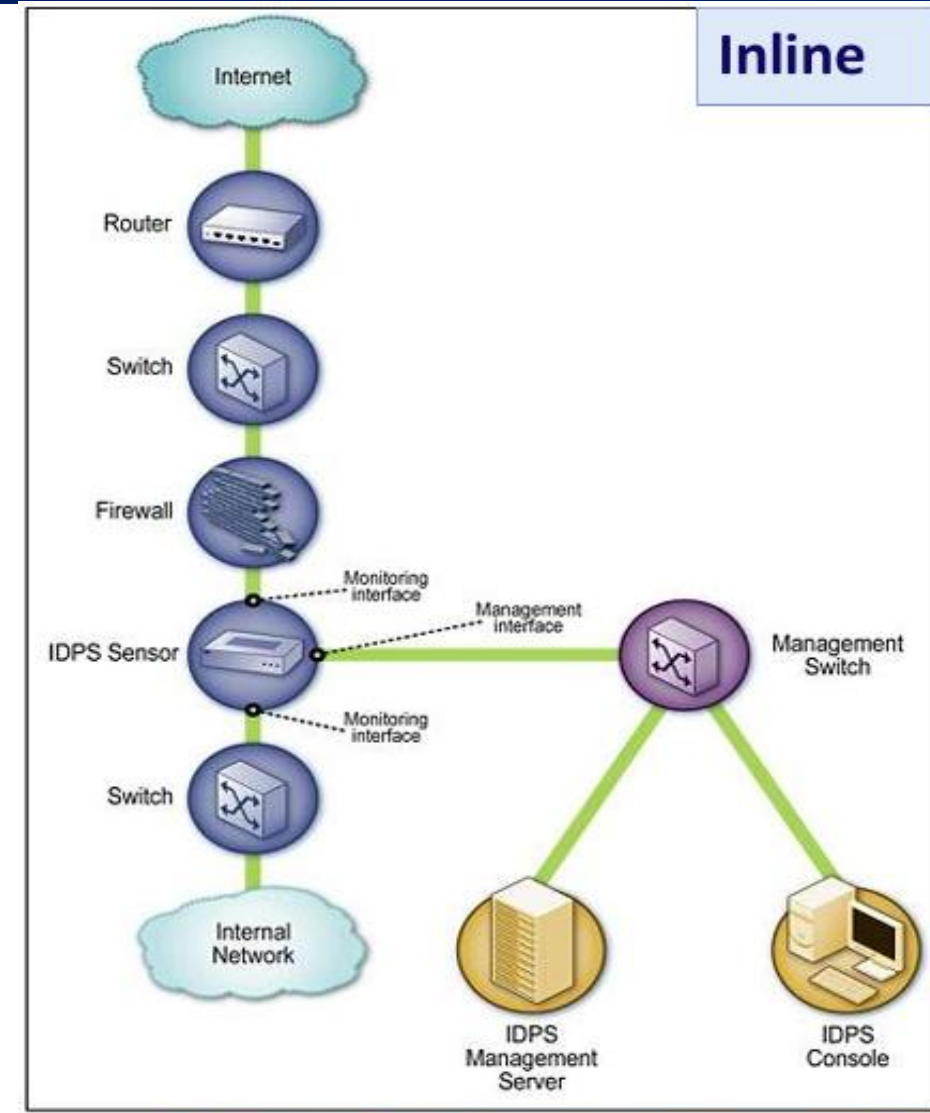
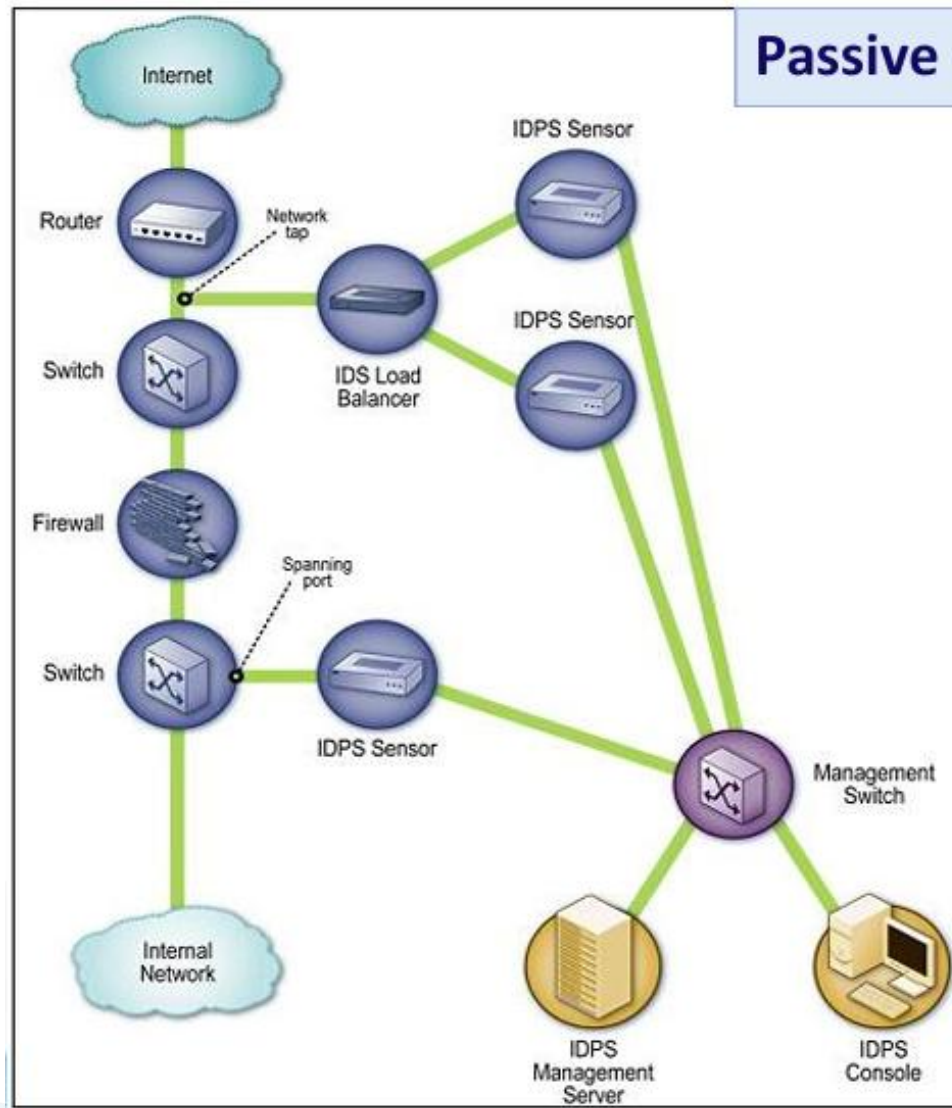
- ❑ False positives (Dương tính giả): IDS phát hiện ra tấn công bị sai (thực tế đó là hành vi bình thường) Đây là hạn chế của Anomaly-based IDS
- ❑ False Negative(Âm tính giả): là một lỗi khá nghiêm trọng khi IDS phát hiện ra hành vi bình thường bị sai và chấp nhận cho vào hệ thống, không phát hiện ra đó thực tế là tấn công(bởi các hành động tấn công tinh vi khó nhận biết).
- ❑ Đây là hạn chế của Signature-based IDS

- ❑ Host-Based IDS là phần mềm chuyên dụng kiểm tra hoạt động của người dùng và phần mềm trên máy chủ cụ thể
 - Phát hiện xâm nhập, đăng nhập các sự kiện đáng ngờ, và gửi thông báo
 - Có thể phát hiện cả sự xâm nhập từ bên ngoài và nội bộ
- ❑ Hai phương pháp tiếp cận, thường được sử dụng kết hợp:
 - Phát hiện dựa vào bất thường - định nghĩa bình thường / hành vi dự kiến
 - Phát hiện ngưỡng
 - Dựa hồ sơ hành vi
 - Phát hiện dựa vào dấu hiệu - xác định hành vi thích hợp

- ❑ Network-Based IDS (NIDS) là phần mềm hoặc phân cứng chuyên dụng kiểm tra lưu lượng mạng hướng đến các hệ thống máy tính có khả năng bị tấn công trên mạng
 - Giám sát lưu lượng truy cập tại các điểm được chọn trên mạng trong (gần) thời gian thực để phát hiện các kiểu xâm nhập
 - Có thể kiểm tra hoạt động giao thức cấp độ mạng, vận chuyển, ứng dụng
 - Vị trí NIDS: đặt ở đầu các vùng mạng LAN, DMZ, tiếp giáp với Internet.
 - Có thể tạo ra nút thắt cổ chai làm giảm tốc độ chung của mạng

□ Thành phần của NIDS điển hình bao gồm:

- Một số cảm biến để giám sát lưu lượng gói, được triển khai 2 kiểu: inline và passive
- Một hoặc nhiều máy chủ cho các chức năng quản lý NIDS
- Một hoặc nhiều bảng điều khiển quản lý cho giao diện con người.



NIDS cũng sử dụng 2 kỹ thuật phát hiện chính là:

❑ Phát hiện dựa vào dấu hiệu: phân tích các giao thức để phát hiện các hành vi tấn công như:

- Quét và tấn công các lớp trong OSI như Application, Transport, Network
- Hoạt động của các ứng dụng / dịch vụ ko mong đợi
- Sử dụng các dịch vụ / giao thức vi phạm chính sách bảo mật

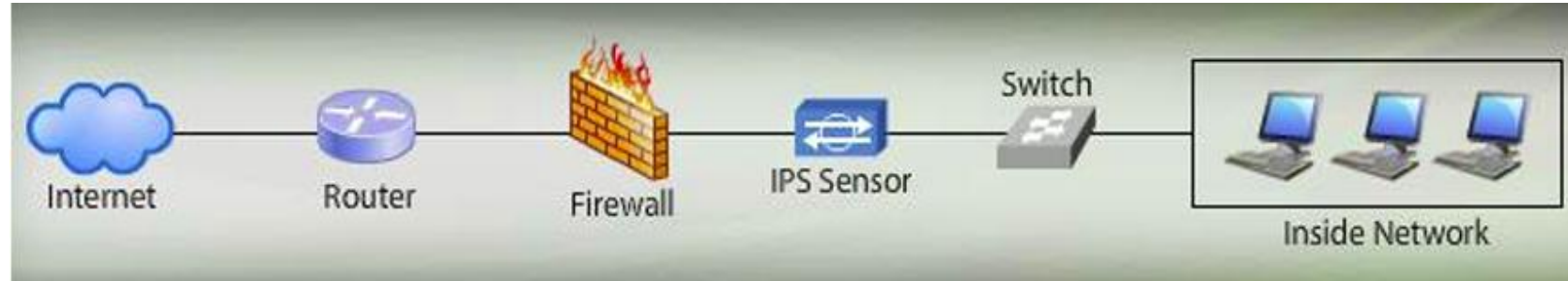
NIDS cũng sử dụng 2 kỹ thuật phát hiện chính là:

❑ Phát hiện dựa vào bất thường: quan sát các bất thường của mạng để phát hiện các tấn công như

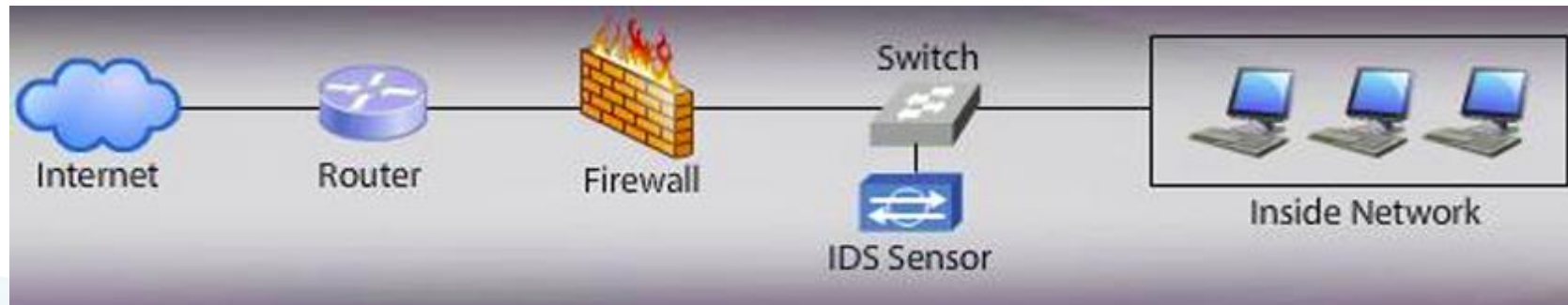
- Dos: tăng đáng kể lưu lượng hay các nỗ lực kết nối, nhằm áp đảo hệ thống mục tiêu
- Scanning: thăm dò hệ thống mục tiêu bằng cách gửi các loại gói khác nhau để tìm hiểu nhiều đặc điểm/lỗ hổng của hệ thống
- Worm: sử dụng lượng băng thông lớn

- ❑ **Hệ thống ngăn ngừa xâm nhập IPS:** là hệ thống theo dõi, ngăn ngừa kịp thời các hoạt động xâm nhập trái phép vào hệ thống. Được xem là trường hợp mở rộng của hệ thống IDS, sử dụng tập luật tương tự như hệ thống IDS
- ❑ **IPS có hai loại:**
 - **Network-Based IPS:** thường được triển khai trước hoặc sau firewall
 - **Host-Based IPS:** được triển khai với mục đích là phát hiện và ngăn chặn kịp thời các hoạt động thâm nhập trên các host

Sơ đồ triển khai IPS – Inline: Sensor ở vị trí mà luồng traffic đó đi qua, bảo vệ khỏi các cuộc tấn công nguy hiểm trong thời gian thực

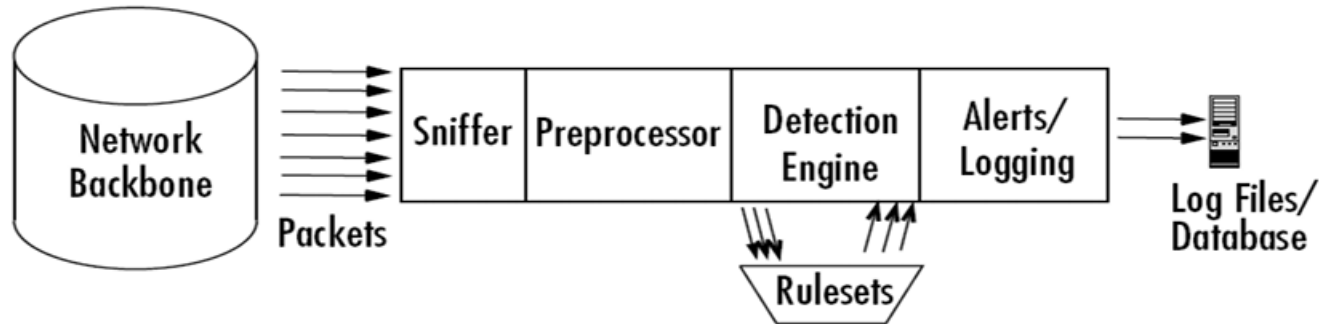


Sơ đồ triển khai IPS – Passive: Sensor sẽ xử lý bản copy của luồng traffic



- ❑ IDS/IPS cứng: thiết bị chuyên dụng của một số nhà sản xuất Trendmicro, Palo Alto...
- ❑ IDS/IPS mềm: phần mềm mã nguồn mở IDS phổ biến:
 - NIDS/IPS engines phổ biến: Snort, Suricata
 - HIDS phổ biến: OSSEC/Wazuh
 - Network Security Monitoring: Zeek (Bro)
 - Platform triển khai: Security Onion

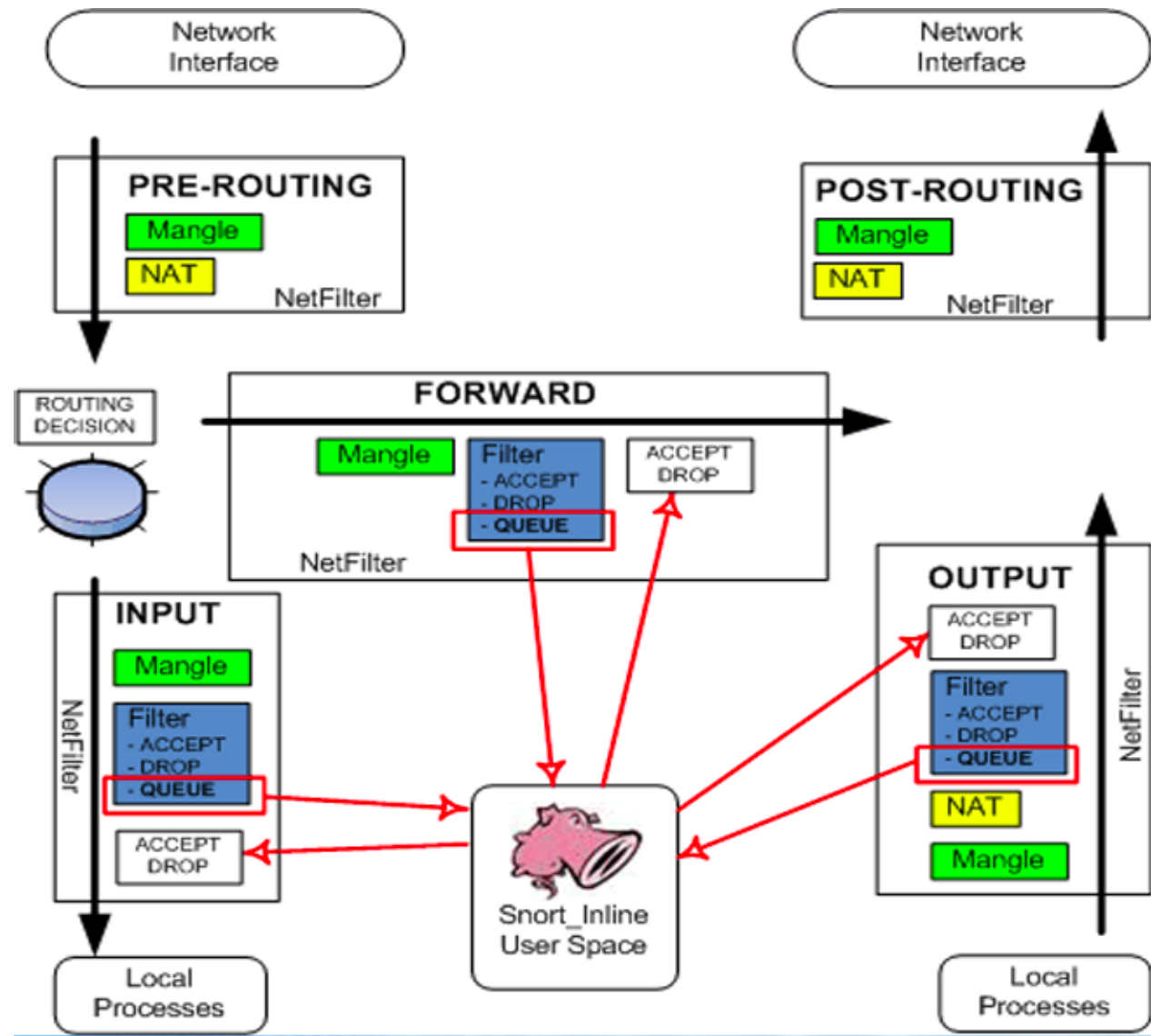
Sơ đồ hoạt động của Snort



Rule (luật) được thiết lập gồm các thành phần:



- ❑ Snort-inline IPS là phiên bản sửa đổi của Snort IDS
- ❑ Nó nhận các gói được gửi từ Firewall Netfilter, so sánh chúng với các rule dấu hiệu của Snort và gắn thẻ chúng là loại bỏ nếu chúng khớp với rule, sau đó gửi chúng trở lại Netfilter nơi các gói được gắn thẻ Snort_Inline bị loại bỏ.



- ❑ Firewall: khái niệm, nguyên tắc hoạt động, các dạng firewall
- ❑ IDS/IPS: khái niệm, nguyên tắc hoạt động, các kỹ thuật IDS/IPS



AN TOÀN THÔNG TIN (INSE330380)

Kết thúc chương 6

Ths. ĐỖ MINH HẬU



Trung tâm Học liệu và Dạy học số
Đại học Công nghệ Kỹ thuật Tp. Hồ Chí Minh
01 Võ Văn Ngân, P. Thủ Đức, Tp. Hồ Chí Minh
daotaotuxa@hcmute.edu.vn